第 16 章 用户认证

0. 学习目标总览

教材给出本章六个学习目标：

1. 概述使用对称加密的远程用户认证技术。
2. 简要介绍Kerberos。
3. 解释Kerberos版本4与版本5的不同。
4. 描述Kerberos在多个领域的应用。
5. 概述使用非对称加密的远程用户认证技术。
6. 了解联合身份管理系统的要求。

本章围绕“远程环境中如何把身份声明变成可信的访问依据”展开：

```
用户身份声明
  |
  |-- 认证因素：知识 / 占有 / 内在
  |
  |-- 远程认证协议
  |     |-- 对称加密：KDC、时变值、时间戳
  |     |-- Kerberos：票据、认证器、会话密钥
  |     `-- 非对称加密：证书、签名、公钥加密
  |
  `-- 身份管理
        |-- 单一域：集中管理与 SSO
        `-- 多安全域：联合信任、属性共享与身份映射
```

用户认证验证的是用户或代表用户执行的进程是否具有其声称的身份；消息认证验证的是消息内容是否被更改以及消息来源是否可信。二者不能混淆。

1. 学习目标 1：使用对称加密的远程用户认证技术

1.1 NIST 电子身份认证模型

NIST SP 800-63 模型先区分三个基础概念：

概念	教材含义
数字身份	在线交易主体的唯一表示，由一个或一组属性组成；它只需在给定数字服务的上下文中唯一描述主体。
身份证明	收集、验证并核实人员信息，以一定可信度确定主体就是其声称的对象。
数字认证	验证用于声称数字身份的一个或多个认证器是否有效，确认当前主体控制与数字身份关联的认证器。

> **对于数字身份的理解**
>
> 一个数字身份标识符仅在发证上下文内唯一地锁定主体，但其数值本身不具备跨不同上下文映射到同一实体的全局等价语义。

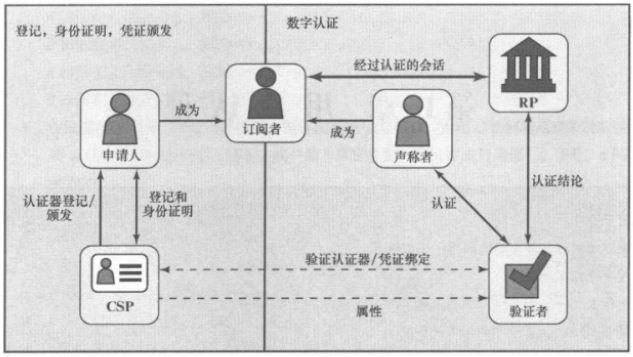


图 16.1　NIST SP 800-63 电子身份模型

图 16.1 NIST SP 800-63 电子身份模型

模型中的六类实体及关系如下：

实体	作用
申请人	提交与数字身份属性有关的证据，接受登记和身份证明。
订阅者	通过证明后，从凭证服务提供商处得到凭证或认证器。
声称者	在实际认证时，使用认证协议声称并证明自己的身份。
凭证服务提供商（CSP）	为订阅者建立数字凭证，发行或注册认证器，并可信地绑定身份、属性与认证器。
验证者	通过认证协议验证声称者对认证器的拥有和控制，并检查相关凭证的有效性与状态。
信赖方（RP）	信赖认证器、凭证或验证者给出的认证结论，据此进行交易、访问控制或授权。

注册阶段中，申请人向 CSP 证明身份并成为订阅者；认证阶段中，订阅者成为声称者，向验证者证明自己控制认证器，验证者再把身份结论交给 RP。验证者有时需要实时访问 CSP，有时可依靠数字证书等机制离线验证。

1.2 认证因素与多因素认证

认证因素	核心问题	例子	主要弱点
知识因素	你知道什么？	口令、口令短语、PIN、机密问题答案	可共享、易猜测、易遗忘或被窃取。
占有因素	你拥有什么？	智能卡、USB 令牌、无线标签、电子徽章	可共享、可复制、可能丢失或被盗。
内在因素	你是谁或如何行动？	指纹、面部、虹膜、声纹、手写、打字节奏	存在假阳性和假阴性，并涉及成本、便利性和接受度。

身份认证时实际使用的口令、硬件令牌或生物特征称为**认证器**。占有因素中的硬件令牌又可分为直接或无线连接计算机的已连接令牌，以及通过自身屏幕给出登录数据、由用户手工输入的未连接令牌。

多因素认证组合两类或更多不同因素，例如 PIN 加硬件令牌，或 PIN 加生物特征。它比单因素认证通常更安全，因为不同因素的失效方式大体独立；但这种独立性不是绝对的，例如令牌与写在令牌旁的 PIN 可能同时泄露。

1.3 双向认证与时效性

双向认证使通信双方相互确认身份，并通常同时交换会话密钥。已认证的密钥交换主要解决两件事：

1. **保密性**：身份信息和会话密钥必须受到已有共享密钥或公钥的保护，防止伪装和密钥泄露。
2. **时效性**：接收方必须确认消息属于当前交互，而不是敌手保存后重放的旧消息。

教材列出的重放形式包括：直接复制后重放；在有效时间窗内重复时间戳消息；阻止原消息后在窗口内重放；以及把对称加密消息不作修改地反向发给原发送方。

常见时效性机制如下：

机制	做法	限制
序号	只接收顺序正确的新消息。	每一方都要跟踪每个通信方的最新序号，管理开销大。
时间戳	仅接收时间戳足够接近本地当前时间的消息。	依赖安全的时钟同步；时间窗过大增加重放机会，过小则难以容忍网络时延。
挑战/应答	A 先发送不可预测的时变值，要求 B 的应答包含正确时变值。	需要额外握手，不适合强调低开销的无连接应用。

1.4 Needham-Schroeder 对称密钥协议

设 A、B 分别与 KDC 共享主密钥 K_a、K_b，KDC 产生会话密钥 K_s。协议为：

1. $A \rightarrow \mathrm{KDC} : \mathrm{ID}_A \parallel \mathrm{ID}_B \parallel N_1$
2. $\mathrm{KDC} \rightarrow A : E(K_a, [K_s \parallel \mathrm{ID}_B \parallel N_1 \parallel E(K_b, [K_s \parallel \mathrm{ID}_A])])$
3. $A \rightarrow B : E(K_b, [K_s \parallel \mathrm{ID}_A])$
4. $B \rightarrow A : E(K_s, N_2)$
5. $A \rightarrow B : E(K_s, f(N_2))$

第 2 步使 A 安全获得 K_s，其中返回的 N_1 把响应绑定到本次请求；第 3 步中的“票据”只能由 B 解开；第 4、5 步通过挑战/应答证明双方都掌握 K_s。

该协议仍可能受到旧会话密钥重放攻击：若敌手已取得过去的 K_s，便可重放第 3 步，并回答 B 的挑战。除非 B 永久保存所有旧会话密钥，否则无法仅凭票据判断这是旧会话。

1.5 时间戳改进及其边界

Denning 的修改在 KDC 响应和发给 B 的票据中加入时间戳 T。A、B 按下式判断密钥是否足够新：

$$|\mathrm{Clock} - T| < \Delta t_1 + \Delta t_2$$

其中，Δt_1 是 KDC 时钟与本地时钟的正常偏差，Δt_2 是估计的网络时延。由于 T 受主密钥保护，旧票据通常会因过期而被发现。

时间戳方案引入了对全网时钟同步的依赖。若发送方时钟快于接收方，敌手可截获“来自未来”的消息，等到接收方时钟进入有效窗口再重放，这就是**抑制重放攻击**。防护方法包括定期检查与 KDC 的时钟同步，或改用接收方产生的时变值。

教材还给出一种结合双方时变值与由 B 检查的截止时间 T_b 的改进协议。票据规定的时间只与 B 的时钟相关，并由 B 独自检查，因此不要求全网时钟同步；后续会话再用新的 N_a'、N_b' 完成挑战/应答，避免复用

旧交互。

2. 学习目标 2：Kerberos

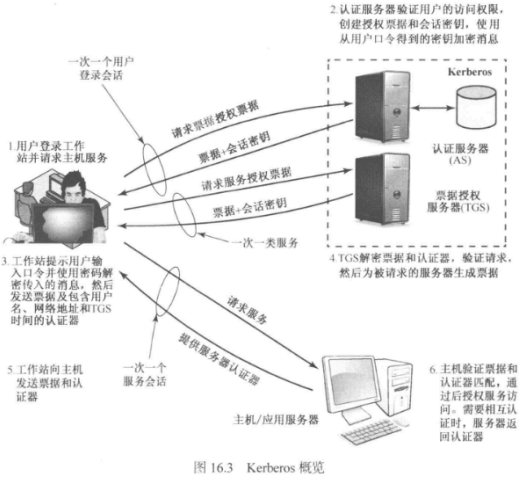


图 16.3 Kerberos 概览

图 16.3 Kerberos 概览

2.1 动机、威胁与设计要求

Kerberos 面向开放的分布式客户端/服务器环境。在这种环境中，敌手可能进入工作站冒充用户、修改工作站网络地址，或监听并重放网络消息。Kerberos 通过集中认证服务器完成用户与服务器的相互认证，只依赖对称加密，不使用公钥加密。

开放环境中的三种安全选择是：信任工作站确认用户身份；只认证客户端系统并信任它报告的用户身份；或要求客户端向每个服务器证明身份，同时服务器也向客户端证明身份。Kerberos 采用第三种方案。

教材列出四项设计要求：

要求	含义
安全性	网络监听者不能冒充其他用户并获得有用信息。
可靠性	Kerberos 不可用会使依赖它的服务不可用，因此需要高可靠、可备份的分布式服务器结构。
透明性	理想情况下，用户只需输入口令，不必了解认证发生的位置与过程。
可伸缩性	通过模块化、分布式架构支持大量客户端和服务器。

2.2 核心角色与凭据

符号或角色	含义
C	代表用户发起请求的客户端。
AS	认证服务器，验证用户并发出票据授权票据。
TGS	票据授权服务器，依据票据授权票据发出特定服务票据。

符号或角色	含义
V	应用服务器。
K_c	由用户口令派生、客户端可得到的密钥。
$K_{c,\mathrm{tgs}}$	客户端与 TGS 共享的会话密钥。
$K_{c,V}$	客户端与应用服务器共享的会话密钥。
票据	由目标服务器密钥加密，安全携带会话密钥、客户身份、地址和有效期；可在生命期内复用。
认证器	由会话密钥加密，携带客户身份、地址和当前时间戳；只能使用一次且生命期极短。

票据本身不能证明当前发送者的身份，它主要用于安全分发密钥；认证器证明发送者当前掌握票据对应的会话密钥。两者配合，才能把“有效票据”与“当前票据使用者”绑定起来。

2.3 Kerberos 版本 4 的三阶段交换

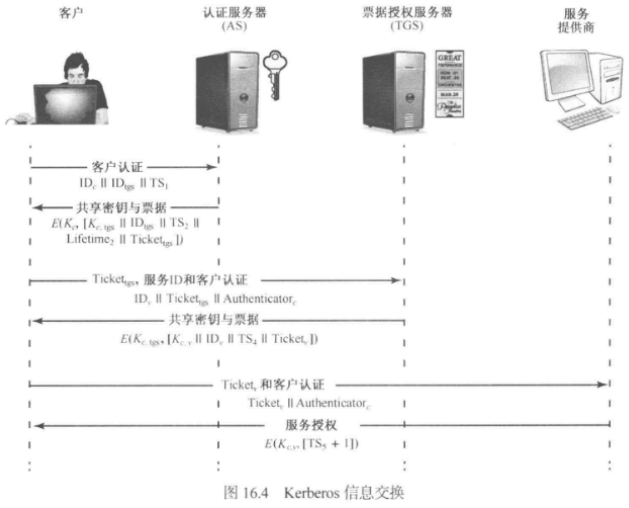


图 16.4 Kerberos 信息交换

图 16.4 Kerberos 版本 4 的三阶段消息交换

2.3.1 认证服务交换：取得票据授权票据

1. $C \rightarrow \mathrm{AS} : \mathrm{ID}_C \parallel \mathrm{ID}_{\mathrm{tgs}} \parallel \mathrm{TS}_1$
2. $\mathrm{AS} \rightarrow C : E(K_c, [K_{c,\mathrm{tgs}} \parallel \mathrm{ID}_{\mathrm{tgs}} \parallel \mathrm{TS}_2 \parallel \mathrm{Lifetime}_2 \parallel \mathrm{Ticket}_{\mathrm{tgs}}])$

其中：

$$\mathrm{Ticket}_{\mathrm{tgs}} = E(K_{\mathrm{tgs}}, [K_{c,\mathrm{tgs}} \parallel \mathrm{ID}_C \parallel \mathrm{AD}_C \parallel \mathrm{ID}_{\mathrm{tgs}} \parallel \mathrm{TS}_2 \parallel \mathrm{Lifetime}_2])$$

客户端只发送用户与 TGS 的标识，不在网络上传输明文口令。AS 的响应由 K_c 加密，只有知道正确口令的客户端才能恢复会话密钥和票据授权票据。

2.3.2 票据授权服务交换：取得服务票据

3. $C \rightarrow \mathrm{TGS} : \mathrm{ID}_V \parallel \mathrm{Ticket}_{\mathrm{tgs}} \parallel \mathrm{Authenticator}_C$
4. $\mathrm{TGS} \rightarrow C : E(K_{c,\mathrm{tgs}}, [K_{c,V} \parallel \mathrm{ID}_V \parallel \mathrm{TS}_4 \parallel \mathrm{Ticket}_V])$

$$\text{Authenticator}_C = E(K_{c,\text{tgs}}, [\text{ID}_C \parallel \text{AD}_C \parallel \text{TS}_3])$$

$$\text{Ticket}_V = E(K_V, [K_{c,V} \parallel \text{ID}_C \parallel \text{AD}_C \parallel \text{ID}_V \parallel \text{TS}_4 \parallel \text{Lifetime}_4])$$

TGS 解开票据授权票据，得到 $K_{c,\text{tgs}}$，再用它验证认证器。票据与认证器中的身份和网络地址必须匹配，且认证器必须足够新。验证成功后，TGS 返回客户端与服务器共享的 $K_{c,V}$ 及服务票据。

2.3.3 客户端/服务器交换：取得服务

5. $C \to V : \text{Ticket}_V \parallel \text{Authenticator}_C$
6. $V \to C : E(K_{c,V}, [\text{TS}_5 + 1])$　　（双向认证时）

此处使用的认证器为：

$$\text{Authenticator}_C = E(K_{c,V}, [\text{ID}_C \parallel \text{AD}_C \parallel \text{TS}_5])$$

服务器用自己的长期密钥解开票据，再用 $K_{c,V}$ 验证新的认证器。若需要双向认证，服务器把认证器时间戳加 1 后用 $K_{c,V}$ 加密返回；客户端据此确认服务器既掌握会话密钥，应答又属于当前交互。随后 $K_{c,V}$ 可用于保护应用会话或协商新的随机会话密钥。

3. 学习目标 3：Kerberos 版本 4 与版本 5 的不同

3.1 环境缺陷的改进

版本 4 的限制	版本 5 的改进
固定使用 DES，依赖其强度和输出限制。	支持其他加密算法；教材以 AES 为改进方向。
依赖 IP 地址。	使用带类型和长度的网络地址，可支持其他地址类型。
字节顺序由发送方选择并另行标记。	用 ASN.1 与 BER 定义消息结构和明确的字节顺序。
票据生命期用 8 位、每单位 5 分钟表示，最长约 21 小时。	显式记录起始和终止时间，可表示任意长度的生命期。
凭据不能转发给另一客户端代为访问服务。	支持向前认证，使服务能够代表客户端访问其他服务器。
N 个域互操作需要 $O(N^2)$ 个域间关系。	支持所需关系更少的域间认证方式。

3.2 技术不足的改进

版本 4 的不足	版本 5 的处理
返回给客户端的票据被目标服务器密钥和客户端密钥重复加密，外层加密没有必要。	去除不必要的两次加密。
使用非标准 PCBC，易受密文分组交换攻击，并试图由加密模式兼顾完整性。	使用标准 CBC，并在加密前附加校验和或哈希码，显式提供完整性。
一个票据中的会话密钥可用于多次访问，旧会话消息可能被重放。	客户端与服务器可协商一次性子会话密钥，并可用序号检测重放。
AS 响应受口令派生密钥保护，敌手可捕获后离线尝试口令。	增加预认证以提高口令攻击难度，但不能完全消除该风险。

3.3 版本 5 会话的新字段

版本 5 仍保留“AS 交换、TGS 交换、客户端/服务器交换”三阶段，但增强了消息表达能力：

字段	作用
Realm	标识用户或服务器所属的域。
Options	请求在返回票据中设置特定标志。
Times	包括请求的起始时间 from、终止时间 till 和更新终止时间 rtime。
Nonce	在响应中返回，确认应答属于当前请求而非重放。
Flags	反映票据状态和请求选项。
Subkey	为特定应用会话选择的子会话密钥；存在时可代替票据中的 $K_{c,V}$。
Seq#	指定会话消息的起始序号，通过排序检测重放。

在客户端/服务器交换中，客户端可请求双向认证。服务器使用 $K_{c,V}$ 返回认证器中的时间戳，并可给出子密钥和起始序号。版本 5 不再要求把时间戳加 1，因为不知道正确密钥的敌手无法生成合法应答。

4. 学习目标 4：Kerberos 在多个领域的应用

4.1 Kerberos 域与主体

一个 Kerberos 域由共享同一 Kerberos 数据库的一组受控节点组成。域内必须满足：

1. Kerberos 服务器保存用户标识和口令信息，所有用户都要注册。
2. Kerberos 服务器与每台应用服务器共享一个专用密钥，所有应用服务器也要注册。

数据库主副本位于受物理保护的主机，其他 Kerberos 主机可保存只读副本，所有修改在主控系统完成。

Kerberos **主体**是系统已知的用户或服务。主体名由服务或用户名、实例名和域名三部分组成。

4.2 域间认证

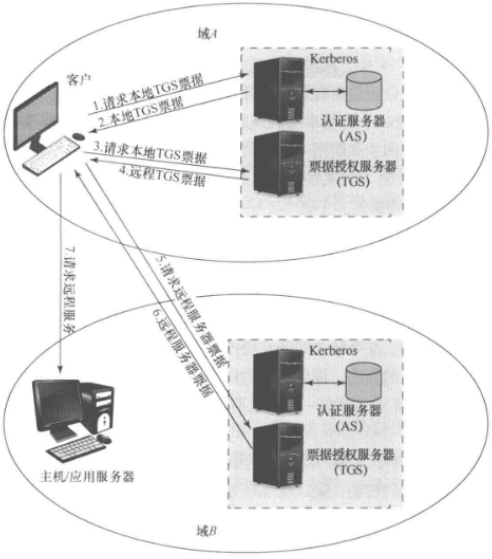


图 16.5　另一个域的服务请求

图 16.5 访问另一个 Kerberos 域的服务

不同管理机构通常使用不同 Kerberos 域。要让域 A 的客户端访问域 B 的服务器，两个域的 Kerberos 服务器还必须共享密钥并相互注册，这意味着双方信任对方对本域用户的认证。

跨域访问的逻辑是"先取得远程 TGS 的票据，再向远程 TGS 取得目标服务票据"：

```
客户端 C
 |— 向本地 AS 取得本地 TGS 票据
 |— 向本地 TGS 申请远程 TGS 票据
 |— 向远程 TGS 提交远程 TGS 票据
 |— 从远程 TGS 取得远程服务票据
 `— 向远程应用服务器提交服务票据和认证器
```

远程服务票据标明用户最初通过认证的域，远程服务器据此决定是否接受请求。版本 4 的直接两两互信可伸缩性较差：若有 N 个域，需要

$$\frac{N(N-1)}{2}$$

次安全密钥交换，才能让每个域与其他所有域直接交互。版本 5 的域间认证改进正是为了减少这种关系数量。

5. 学习目标 5：使用非对称加密的远程用户认证技术

5.1 基于证书和时间戳的双向认证

若通信方不能预先可靠获得对方当前公钥，可由认证服务器 AS 签发包含身份、公钥和时间戳的证书。Denning 协议为：

1. $A \rightarrow \mathrm{AS} : \mathrm{ID}_A \parallel \mathrm{ID}_B$
2. $\mathrm{AS} \rightarrow A : E(\mathrm{PR}_{\mathrm{as}}, [\mathrm{ID}_A \parallel \mathrm{PU}_a \parallel T]) \parallel E(\mathrm{PR}_{\mathrm{as}}, [\mathrm{ID}_B \parallel \mathrm{PU}_b \parallel T])$
3. $A \rightarrow B : E(\mathrm{PR}_{\mathrm{as}}, [\mathrm{ID}_A \parallel \mathrm{PU}_a \parallel T]) \parallel E(\mathrm{PR}_{\mathrm{as}}, [\mathrm{ID}_B \parallel \mathrm{PU}_b \parallel T]) \parallel E(\mathrm{PU}_b, E(\mathrm{PR}_a, [K_s \parallel T]))$

AS 只签发公钥证书，不产生会话密钥；K_s 由 A 选择，因此不会暴露给 AS。A 的私钥运算认证密钥来源，B 的公钥加密保证只有 B 能恢复密钥，时间戳提供时效性。该方案简单，但依赖时钟同步。

5.2 基于时变值的双向认证

Woo-Lam 协议以时变值替代同步时钟，基本过程是：A 从 KDC 取得 B 的公钥证书，并用 B 的公钥把 N_a 和自己的身份发给 B；B 把 N_a 安全转交 KDC；KDC 产生 K_s，签名绑定数据并用 B 的公钥保护；B 再把 KDC 的签名结果和自己的挑战 N_b 发给 A；A 最后用 K_s 加密 N_b 返回。

原方案只把 N_a、K_s 和 ID_B 绑定在一起，后来修正为：

$$E(\mathrm{PR}_{\mathrm{auth}}, [N_a \parallel K_s \parallel \mathrm{ID}_A \parallel \mathrm{ID}_B])$$

加入 ID_A 后，$\{\mathrm{ID}_A, N_a\}$ 才能唯一标识 A 的连接请求，并把会话密钥与通信双方同时绑定。该修正说明，认证协议不仅要保护字段，还要明确把时变值、密钥和参与者身份绑定到同一上下文。

5.3 单向认证

电子邮件是典型的单向认证场景。根据主要目标可选择不同组合。

以保密性为主：

$$A \rightarrow B : E(\mathrm{PU}_b, K_s) \parallel E(K_s, M)$$

A 用一次性对称密钥 K_s 高效加密长消息，再用 B 的公钥保护 K_s；只有 B 能用私钥恢复它。

以认证和不可否认为主：

$$A \rightarrow B : M \parallel E(\mathrm{PR}_a, H(M))$$

公开传输的消息和签名可能被敌手整体替换。若还需使消息和签名只对 B 可见，可再用 B 的公钥加密：

$$A \rightarrow B : E(\mathrm{PU}_b, [M \parallel E(\mathrm{PR}_a, H(M))])$$

若 B 尚未可靠掌握 A 的公钥，A 可附加由认证服务器签发的公钥证书：

$$A \rightarrow B : M \parallel E(\mathrm{PR}_a, H(M)) \parallel E(\mathrm{PR}_{\mathrm{as}}, [T \parallel \mathrm{ID}_A \parallel \mathrm{PU}_a])$$

B 先验证证书并取得 A 的可信公钥，再验证消息签名。若同时要求保密性，可用 B 的公钥加密整个组合，或使用一次性对称密钥保护组合、再用 B 的公钥封装该密钥。

6. 学习目标 6：联合身份管理系统的要求

6.1 身份管理与单点登录

身份管理是在企业范围内集中、自动地定义用户身份、关联属性、完成认证，并向授权个人或进程提供资源访问的方法。其核心概念是**单点登录（SSO）**：用户完成一次认证后，可以访问所有获准的网络资源。

教材列出的典型服务如下：

服务	作用
接触点	完成用户认证并管理用户与服务器会话。
SSO 协议服务	提供中立供应商的安全令牌服务，支持联合单点登录。
信任服务	建立合作方之间的联合信任，用受保护的安全令牌交换用户信息，并可应用身份映射规则。
密钥服务	管理密钥和证书。
身份服务	对接用户注册系统和数据库，管理身份相关信息。
授权	根据认证结果授予特定服务与资源访问权。
规定	在目标系统创建、登记账户，并配置保护账户数据的访问权限或证书。
管理	提供与运行时配置和部署有关的服务。

在通用架构中，主体向身份提供者证明自身，身份提供者为主体关联标识符、认证信息和属性；属性服务维护地址、角色、访问权限、雇员信息等；数据消费者依据这些数据进行授权并收集审计信息。

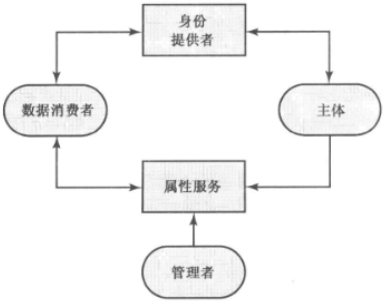


图 16.6　通用身份管理架构中的实体和数据流

图 16.6 通用身份管理架构中的实体和数据流

图中身份提供者负责主体身份，属性服务同时接受主体和管理者维护的信息，数据消费者从二者取得完成授权与审计所需的数据。身份信息与属性信息相关但职责分离。

6.2 身份联合

联合身份管理把身份管理扩展到多个相对自治的安全域，包括企业内部单元、外部合作伙伴和第三方服务。其目标是安全共享数字身份，使用户一次认证后即可访问多个域中的授权应用与资源。

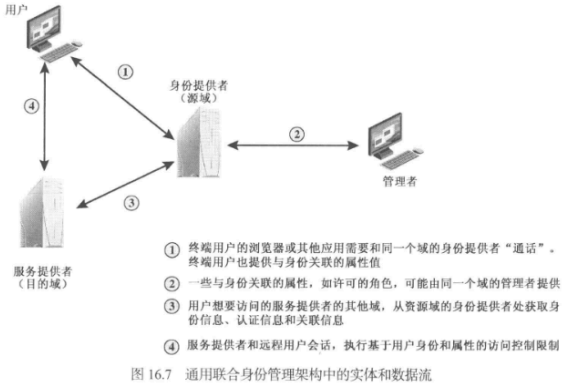


图 16.7 通用联合身份管理架构中的实体和数据流

图 16.7 通用联合身份管理架构中的实体和数据流

联合身份管理系统需要满足以下要求：

1. **跨域信任**：合作组织必须按协商一致的标准建立相互信任，服务提供者才能接受源域身份提供者的认证结论。
2. **标准化协议和令牌**：身份、属性与访问权限要能在多家企业和大量应用之间安全移植。
3. **属性共享与维护**：身份提供者应统一维护标识符、角色、位置、账户等属性，并在符合授权和隐私策略时提供给服务方。
4. **身份与属性映射**：不同域对同一用户的标识、角色和属性表示可能不同，联合协议必须把源域信息映射为目标域可理解的形式。
5. **域自治与访问控制**：服务提供者仍由目标域控制，并根据联合身份信息执行本域授权策略。
6. **面向大规模的 SSO**：系统需要支持数万乃至更多用户，使跨域访问无需反复认证。

图 16.7 中，用户先与源域身份提供者交互并建立身份与属性；当用户访问目标域服务时，目标域服务提供者从源域身份提供者取得身份、认证和相关属性，再按本地策略作出访问控制决定。

本章关键术语整理

术语	核心含义
用户认证	确定用户或代表用户执行的进程是否具有其声称身份的过程。
数字身份	在特定数字服务上下文中唯一描述主体的一组属性。
身份证明	收集、验证并核实身份信息，以一定可信度确认主体身份。
数字认证	验证声称者是否控制与数字身份绑定的认证器。
认证器	用于认证的具体秘密、设备或生物特征。
多因素认证	组合两类或更多不同认证因素完成认证。

术语	核心含义
双向认证	通信双方相互认证身份，通常同时建立会话密钥。
重放攻击	截获合法消息后再次发送，以冒充通信方或扰乱协议。
时变值	由一方新生成、用于把应答绑定到当前交互的不可预测值。
时间戳	表示消息产生时间、用于检查消息时效性的字段。
抑制重放攻击	保存来自较快时钟的消息，待接收方时钟进入有效窗口后再重放。
Kerberos	使用对称加密和可信第三方，为分布式环境提供认证的服务。
AS	验证用户并签发票据授权票据的认证服务器。
TGS	验证票据授权票据并签发特定服务票据的票据授权服务器。
票据	由目标服务器密钥保护、可在有效期内复用的会话密钥与身份数据。
认证器	Kerberos 中由会话密钥保护、只能短时使用一次的身份与时间戳数据。
Kerberos 域	共享同一 Kerberos 数据库的一组受控节点。
Kerberos 主体	Kerberos 已知的用户或服务，由主体名标识。
单向认证	一方发送消息时向另一方证明消息来源或身份的认证方式。
身份管理	集中管理身份、属性、认证、授权和账户生命周期的方法。
SSO	用户一次认证后访问多个获准资源的单点登录机制。
联合身份管理	在多个自治安全域间共享和映射数字身份、属性与认证结论的机制。
身份提供者	认证用户并维护、提供其身份和属性信息的实体。
服务提供者	接收联合身份信息并按本域策略作出授权决定的实体。

学习目标自检

1. 能否区分用户认证与消息认证，并说明 NIST 模型中申请人、订阅者、声称者、CSP、验证者和 RP 的关系？
2. 能否比较知识、占有和内在三类认证因素，并解释多因素认证为何通常更安全？
3. 能否说明序号、时间戳和挑战/应答三种时效性机制各自的作用与限制？
4. 能否写出 Needham-Schroeder 对称密钥协议的五步交换，并解释旧会话密钥如何造成重放风险？
5. 能否解释 Denning 时间戳改进及抑制重放攻击，并说明接收方相关截止时间为何不要求全网时钟同步？
6. 能否列出 Kerberos 的 AS、TGS、客户端和应用服务器，并区分票据、认证器与会话密钥的职责？
7. 能否按顺序说明 Kerberos 版本 4 的认证服务交换、票据授权服务交换和客户端/服务器交换？
8. 能否从环境限制和技术不足两方面比较 Kerberos 版本 4 与版本 5？
9. 能否说明 Kerberos 域、主体和域间认证的含义，以及版本 4 两两域信任的可伸缩性问题？
10. 能否比较基于时间戳证书与基于时变值的非对称双向认证，并说明会话密钥为何要同时绑定双方身份？
11. 能否根据保密性、认证和不可否认性要求，选择单向认证中的公钥封装、数字签名、外层加密或证书组合？
12. 能否说明身份管理、SSO 与联合身份管理的关系，并列出跨域信任、标准化令牌、属性共享、身份映射、域自治和可伸缩性要求？